



Auditoría externa exhaustiva

Seguridad · RGPD · Arquitectura · Datos/RLS · QA/CI · DevOps · UX/i18n · IA

14 de junio de 2026 · 8 frentes independientes · adversarial y verificada

Veredicto: NO listo para producción

Núcleo asistencial genuino y bien construido; base multitenant RLS sólida (59 tablas verificadas). Pero capa de despliegue/operación ausente, varios críticos de seguridad y red de tests con huecos. Hoja de ruta dentro.

9

Críticos

16

Altos

10

Medios

1

Falso positivo

Detonante: el CIO descubrió que el gate de CI llevaba días en rojo y lo había dado por verde.
Esta auditoría nace de esa falta de honestidad y la corrige: verificar, no validar.

Resumen ejecutivo

Ocho auditores independientes revisaron el proyecto en modo adversarial (encontrar fallos, no validar) y verificando contra el código y, donde fue posible, contra Postgres. El CIO verificó en vivo los hallazgos críticos en lugar de fiarse de los reportes. Resultado: 9 críticos, 16 altos, 10 medios y 1 falso positivo cazado al verificar.

Lo que está bien (verificado)

- Aislamiento multitenant: 59 tablas con tenant_id tienen RLS ENABLE+FORCE+USING+WITH CHECK completos. Es el invariante #1 y se sostiene.
- Patrón de migraciones disciplinado (GRANT guardados con IF EXISTS, columnas IF NOT EXISTS); bundle sin node:crypto en cliente (Web Crypto isomórfico).
- Capa de IA realmente cableada (no vaporware): VllmProvider funcional, prompts versionados es/ca, seudonimización, AuditLog, badge de transparencia AI Act.
- Núcleo asistencial (expediente, atención, MAR, PIA, valoraciones) construido de verdad, con tests de lógica pura y de aislamiento RLS en vivo.

Los problemas de fondo

1. Honestidad/observabilidad: el gate de CI estuvo ROJO días (#198-#218) sin que nadie lo mirara - una migración rompía en BD limpia. Ya CORREGIDO y verificado verde (#222). La causa raíz (divergencia localCI: dev-setup no crea el rol de app, así que en local RLS nunca se ejercita) sigue viva y debe cerrarse.
2. Seguridad: secreto TOTP en claro, auth_tokens sin RLS con grants totales al rol de app, y riesgo de RLS desactivada en producción sin aviso (fail-open).
3. Despliegue/operación: NO existe camino a producción (sin Dockerfile/laC/runbook, sin backups/DR, sin gestión de secretos, sin DPA con el proveedor UE).
4. Red de seguridad de tests con agujeros: los 49 e2e NUNCA corren en CI (solo se parsean); 22/37 permisos RBAC y flujos críticos (MFA, signup, admisiones) sin test de integración.
5. Honestidad de alcance: push notifications declaradas "done" pero MUERTAS de extremo a extremo; IA es stub por defecto; facturación es gestor de facturas, no cobro; i18n incompleto (pantallas enteras en castellano).

Hallazgos críticos (9)

CRÍTICO**SEC-C01 · Seguridad/RGPD****Secreto TOTP almacenado en claro en la BD (mfa_secret TEXT)**

Evidencia: schema.prisma:71; mfa.ts:18-19 (TODO Q-SEC). Confirmado por Sofía, Marc y Pau.

Cifrar la columna con KMS UE-soberano (pgcrypto/Vault Transit) ANTES de activar MFA en producción. Escalar fecha a Angel.

CRÍTICO**DAT-C01 · Datos/RLS****auth_tokens sin RLS y rol vetlla_app con grants totales: lectura cross-tenant de hashes de tokens de reset/invitación**

Evidencia: Verificado en vivo: su migración no tiene RLS/policy; app-role.sql:33 concede CRUD sobre ALL TABLES.

REVOKE ALL ON auth_tokens FROM vetlla_app, o rol dedicado vetlla_auth para flujos de autenticación.

CRÍTICO**DAT-C02 · Datos/RLS****Aforo de actividades sin transacción: dos inscripciones concurrentes superan el aforo**

Evidencia: Verificado en vivo: actividades.ts:242-272 hace countdecidewrite sin \$transaction/Serializable, cuando visits.ts:355 sí lo usa.

Envolver enroll en \$transaction({isolationLevel:"Serializable"}) (patrón ya existente en visitas).

CRÍTICO**ARQ-C01 · Arquitectura/Alcance****Push notifications MUERTAS de extremo a extremo: el service worker no tiene listener push ni notificationclick**

Evidencia: Verificado en vivo: public/sw.js (42 líneas) solo install/activate/fetch. routers/push.ts:37 afirma falsamente que el SW los escucha.

Añadir handlers push + notificationclick al SW, o dejar de declarar la feature como hecha. (El CIO la reportó cerrada sin verificar - error reconocido.)

CRÍTICO**OPS-C01 · DevOps****Sin camino reproducible a producción: ni Dockerfile, ni IaC, ni runbook de arranque**

Evidencia: Leo H-01, Marc A-02. next.config sin output:standalone; sin orden documentado bootstrapmigrateapp-roleseed.

Dockerfile de producción + IaC OVHcloud + runbook. Desbloquea con Q-004 (Angel).

CRÍTICO**OPS-C02 · DevOps/RGPD****Sin DPA firmado con OVHcloud ni Postgres contratado: operar datos de salud (art.9) sin DPA es infracción**

Evidencia: Leo H-03. ADR-0011 elige OVHcloud pero sin credenciales ni DPA ni DPIA cerrada.

Firmar DPA + cerrar DPIA antes de cualquier dato real. Decisión de Angel (Q-004).

CRÍTICO**OPS-C03 · DevOps****Sin backups ni plan de recuperación (DR): inaceptable para datos de salud**

Hallazgos altos (selección de 16)

ALTO

SEC-A01..04 · Seguridad

Endpoints con checks de permiso MANUALES en vez de permissionProcedure (frágil ante roles nuevos)

Evidencia: requests.ts:176/224, comms.ts:721/761, visits.ts:233/629, actividades.portal:393. Sofía A-01..A-04.
Migrar a permissionProcedure(<perm>) para que el guard sea declarativo y testeable.

ALTO

QA-A01 · QA/CI

Los 49 tests e2e NUNCA corren en CI (solo se parsean): flujos críticos zero-verified

Evidencia: Verificado en vivo: ci.yml:138-157 el job Playwright está comentado como PENDIENTE.
Añadir job e2e con playwright install --with-deps chromium + app en :3000. (Ya hay tooling en demo-screenshots.yml para reutilizar.)

ALTO

QA-A02 · QA/CI

22 de 37 permisos RBAC sin ningún test + routers mfa/signup/admisiones/actividades sin test de integración

Evidencia: Quim H-02/H-03/H-04/H-07. billing/admissions/activities/inventory/shifts... sin cobertura.
Tests de matriz RBAC (rol sin permiso = rechazo) + integración de los flujos transaccionales.

ALTO

ARQ-A03 · Arquitectura/DevOps

Divergencia localCI: dev-setup.sh no provisiona vetlla_app, así que en local RLS y el modelo de privilegios NUNCA se ejercitan

Evidencia: Marc A-03, Leo H-17. Es la raíz que ocultó el bug del REVOKE.
Hacer que dev-setup ejecute app-role-bootstrap.sql + app-role.sql y que la app local use APP_DATABASE_URL.

ALTO

DAT-A02 · Datos/RLS

Tablas hijas con tenant_id propio pero sin CHECK cruzado con el padre (riesgo de mezcla por bug de app)

Evidencia: Núria A-03: invoice_lines, activity_enrollments, upp_curings, sync_conflicts, care_plan_*. ...
Trigger/constraint que verifique hijo.tenant_id = padre.tenant_id, o derivar el tenant del padre.

ALTO

DAT-A01 · Datos/RLS

bypass_rls activado en issueInvoice: si se añaden queries a esa transacción, operarían sin aislamiento de tenant

Evidencia: Núria A-02: facturacion.ts:485.
Acotar el bypass a la query de numeración; documentar la invariante.

ALTO

IA-A01 · IA/RGPD

Datos de salud (diagnósticos, alérgenos) van en CLARO al modelo: riesgo de reidentificación

Evidencia: Iris H-01: copilot.ts:350-363. redactPii seudonimiza nombre/DNI pero no las descripciones clínicas.
Enviar solo códigos (CIE-10), no texto libre; base legal art.9.2.h. Antes de cablear modelo real.

ALTO

UX-A01 · UX/i18n

Flujo del auxiliar (atención a pie de cama, tablet) con títulos y opciones en castellano hardcodeado

Evidencia: Elena A-1: atencion/page.tsx (Constantes, Ingesta, comidas como array estático, Sí/No, avisos).

Traducir el flujo más usado; usar `<Select>` del DS en vez de `<select>` nativo.

ALTO

SCO-A01 · Alcance

Email transaccional no operativo: EMAIL_PROVIDER=http en prod pero sin URL/clave el primer piloto no envía resets de contraseña

Evidencia: Pau: .env.example. Guard correcto (fail-fast) pero brecha operativa bloqueante.

Proveer EMAIL_API_URL/KEY (proveedor UE) antes del piloto.

Discrepancias adjudicadas y honestidad

Falso positivo cazado al verificar

Leo reportó ".env commiteado en git con ANTHROPIC_API_KEY" (Crítico). VERIFICADO EN VIVO: .env NO está trackeado (git ls-files solo muestra .env.example; nunca en el historial; .gitignore lo cubre).

Sofía tenía razón. Descartado. Lección: el propio proceso de auditoría comete errores; verificar los cazó.

Discrepancia sobre la madurez de la IA

Pau (honestidad de alcance) la calificó de "stub/simulación, ningún usuario real la usa". Iris

(especialista) la puntuó 7/10 "MVP funcional real, cableado de extremo a extremo con VllmProvider".

Síntesis verificada: la ARQUITECTURA de IA es real (no vaporware), pero es stub POR DEFECTO y no está lista para modelo real (PII en claro, sin validación de región UE). Ambas verdades conviven; se refleja así.

Hallazgo #0 del propio CIO (cerrado y verificado)

El CIO descubrió que ci.yml llevaba rojo desde ~10:19 (#198-#218) por la migración que hace REVOKE ... FROM vetlla_app antes de que el rol exista en BD limpia. Fix aplicado (crear el rol antes de migrate, en ci.yml y demo-screenshots.yml). VERIFICADO: run #222 en main = SUCCESS. El gate de aislamiento RLS vuelve a correr.

Hoja de ruta de remediación

P0 - antes de CUALQUIER piloto con datos reales (equipo, autónomo)

- Cifrar secreto TOTP (KMS UE) [SEC-C01]
- auth_tokens: revocar acceso de vetlla_app / rol dedicado [DAT-C01]
- Aforo de actividades en transacción Serializable [DAT-C02] (fix rápido)
- Reparar el service worker de push o dejar de declararlo hecho [ARQ-C01]
- Fail-fast en arranque si se conecta como owner/superuser (RLS off) [OPS-C04]
- dev-setup provisiona vetlla_app: cerrar la divergencia localCI [ARQ-A03]
- Habilitar los 49 e2e en CI [QA-A01]
- Migrar checks de permiso manuales a permissionProcedure [SEC-A01..04]
- i18n de las 2 pantallas sin traducir + flujo del auxiliar [UX-C01/A01]
- Rate-limit en el paso TOTP del login [SEC-M]

P0 - decisiones/acciones de Angel (negocio/legal)

- DPA + Postgres gestionado UE con OVHcloud (Q-004) [OPS-C02]
- Política de retención/supresión RGPD (Q-003)
- Provisión del rol vetlla_app en el Postgres gestionado (Q-005)

P1 - antes del go-live

- Dockerfile + IaC OVHcloud + pipeline CIdeploy
- Backups + PITR habilitados y restore PROBADO
- Vault/KMS UE + rotación de secretos; correlation-id + error tracking UE
- Tests de matriz RBAC (22 permisos) + integración mfa/signup/admisiones
- IA: enviar solo códigos CIE al modelo + validación de región UE
- Política expand/contract para migraciones; cabeceras de seguridad HTTP

Metodología

8 auditores especializados independientes (Seguridad/RGPD, Arquitectura, QA/CI, DevOps, Honestidad de alcance, Modelo de datos/RLS, UX/i18n, IA), en paralelo, modo adversarial, solo lectura. El CIO verificó en vivo los críticos (CI, RLS, código) en lugar de fiarse de los reportes, y cazó 1 falso positivo. Informes completos en docs/auditoria/2026-06-14/.